

Bachelor's Thesis Proposal

Static Analysis for Personal Data

Assessor: Dr. Hoang Nguyen

Co-assessor: To be decided

1 Motivation

Ensuring that software systems, especially web applications, comply with privacy requirements is a complex and critical challenge. On the one hand, it is complex because laws, such as the GDPR [1], impose strict requirements on how organizations handle (personal) data but offer limited guidance on concrete technical solutions. On the other hand, it is critical because failing to comply with these requirements can result in substantial financial penalties.

For any software system analysis, it is important to know precisely *where* personal data resides in a system and *how* it flows through it. For the large body of existing applications, this information is not documented but is embedded implicitly in the source code. Locating personal data manually across a codebase is tedious, error-prone, and does not scale, which makes automated support highly desirable.

2 Objective

The objective of this thesis is to develop an automated *code scanning* approach that statically analyzes a source codebase to identify personal data: where it is collected, stored, and processed. In the scope of the thesis, we restrict the scanner to a subset of a general-purpose language (e.g., Python).

The scanner should recognize the different categories of personal data (e.g., identifiers, contact details, and special categories of data) and, where feasible, track the flow of such data from its collection points to relevant sinks (persistence, logging, and transmission to third parties).

3 Tasks

1. Study the GDPR notion of personal data and review existing static analysis and taint analysis techniques for detecting sensitive or personal data in source code.
2. Design a code scanning approach that locates personal data declarations and tracks their flow to the relevant sinks.
3. Implement the scanner for a chosen programming language or web framework.
4. Validate the scanner on a set of open-source applications.
5. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation.

Presentation At the end of the thesis, a 20 minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016.
<https://eur-lex.europa.eu/eli/reg/2016/679/oj>.

Thesis Submission Guidelines

Submission Requirements

- **Soft copy:** Submit via email to cse@vgu.edu.vn.
- **Hard copies:** Submit two (02) printed copies to the CSE Office (Room 511, Cluster 3).
- The Thesis cover requires at least 3 days to complete. Please make sure to prepare it at the photocopy shop as soon as possible.

Submission Timeline

- You may submit your Final Thesis Report (soft + hard) up to one week before the deadline.
- Early or late submissions will **NOT** be accepted.

Thesis Title Changes

- If you wish to change your Thesis title, please submit a “Request for Changing Thesis Title” by yourself.
- The request must be sent to us within the first four weeks of the preparation period.

Additional Resources

- Required forms and the Thesis template can be found at [Thesis Resources Link](#).
- Please read the Thesis Guidelines carefully.

Intellectual Property

Project: Static Analysis for Personal Data

Assessor: _____

Student: _____

The student participates in this project at Vietnamese-German University (VGU) as a collaborator under the supervision of the assessor in the course of their studies towards the degree named above. The results produced during the collaboration, including the deliverables listed in Section 4, in particular the source code and the final report, constitute the “Research Results” and are governed by the following terms:

Confidentiality The student keeps the Research Results, together with any other information from the supervising research group at VGU that is declared confidential, confidential. This obligation persists until the student is informed that the intellectual property rights have been protected (e.g. through patent applications or other adequate measures) or that no protection is sought, and in no case for longer than twelve (12) months after completion of the collaboration.

Assignment of rights The student assigns to VGU their rights to the Research Results, including inventions and works protected by copyright. In particular, all rights to the commercial exploitation of the Research Results are ceded to VGU.

Patent cooperation If a patent application is filed for an invention based on the Research Results, the student provides all necessary signatures and remains available to support the application process, e.g. to respond to questions from patent examiners.

By signing below, the parties agree to the terms set out above.

Vietnamese-German University (VGU)

Place, Date

The assessor

The Student

Place, Date

The student